4. Key Findings and Risk Analysis

4.1 Overview of Assessment Findings

The vulnerability assessment conducted on November 3, 2026, identified multiple security weaknesses affecting the Metasploitable virtual machine hosted within the Proxmox laboratory environment.

Greenbone Community Edition reported 66 findings across four technical severity categories.

Technical Severity	Number of Findings
Critical	13
High	8
Medium	39
Low	6
Total	**66**

The assessment prioritized the 13 Critical findings for detailed analysis.

Two results associated with the same vsftpd backdoor vulnerability were consolidated into one risk, resulting in **12 distinct risks** documented in the IT Security Risk Register.

The findings revealed weaknesses involving unauthorized remote access, insecure authentication, vulnerable applications, unsupported operating systems, and exposed network services.

These weaknesses were evaluated using a simulated production scenario to demonstrate how technical vulnerabilities can translate into business risks.

4.2 Inherent Risk Assessment Results

Each registered risk was evaluated using the five-point likelihood and impact methodology described in Section 3.

The resulting provisional inherent risk ratings were:

Inherent Risk Rating	Number of Risks	Percentage
Critical	9	75%
High	3	25%
Medium	0	0%

Inherent Risk Rating	Number of Risks	Percentage
Low	0	0%
Total	**12**	**100%**

Nine risks were assigned Critical inherent risk ratings, while three were assigned High ratings.

These results reflect the assumed consequences of deploying the vulnerable system in a production environment supporting business applications.

They do not represent the actual business risk of the intentionally vulnerable laboratory system.

4.3 Summary of Registered Risks

The following table summarizes the 12 risks documented in the IT Security Risk Register.

Risk ID	Vulnerability / Security Weakness	CVSS	Inherent Risk Score	Risk Rating	Priority
RISK-001	Distributed Ruby Remote Code Execution	10.0	25	Critical	P1
RISK-002	Ingreslock Backdoor	10.0	25	Critical	P1
RISK-003	Passwordless rlogin Root Access	10.0	25	Critical	P1
RISK-004	TWiki XSS and Command Execution Vulnerabilities	10.0	20	Critical	P1
RISK-005	Insecure rexec Service	10.0	12	High	P2
RISK-006	Unsupported Ubuntu 8.04 Operating System	10.0	20	Critical	P1
RISK-007	vsftpd Backdoor	9.8	25	Critical	P1
RISK-008	MySQL Root Account With Empty Password	9.8	25	Critical	P1
RISK-009	Apache Tomcat Ghostcat Vulnerability	9.8	16	High	P2
RISK-010	DistCC Remote Command Execution	9.3	20	Critical	P1
RISK-011	Weak VNC Authentication	9.0	16	High	P2
RISK-012	PostgreSQL Default Credentials	9.0	25	Critical	P1

Assessment Note: CVSS represents technical vulnerability severity. The inherent risk score represents a separate, provisional assessment of likelihood and business impact under the simulated production scenario.

4.4 Key Finding 1 — Unauthorized Remote Command Execution

Associated Risks: RISK-001, RISK-002, RISK-007, RISK-010

Risk Category: Unauthorized Access and System Compromise

Observation

The assessment identified multiple services associated with remote command execution vulnerabilities or backdoor functionality.

The affected services included:

Risk ID	Service	Port	Evidence
RISK-001	Distributed Ruby	8787/TCP	Greenbone received a Ruby exception and call stack in response to a remote syscall test.
RISK-002	Ingreslock	1524/TCP	Greenbone executed `id` and received `uid=0(root)`.
RISK-007	vsftpd	21/TCP and 6200/TCP	Greenbone detected the known vsftpd backdoor vulnerability through active checks.
RISK-010	DistCC	3632/TCP	Greenbone executed `id` and received `uid=1(daemon)`.

The Ingreslock and DistCC findings provided direct evidence of remote command execution.

The Ingreslock result demonstrated execution with Linux root privileges, while the DistCC result demonstrated execution under the less-privileged daemon account.

The Distributed Ruby finding demonstrated exposure to unsafe remote syscall processing, but successful arbitrary command execution was not independently established.

The vsftpd finding was supported by Greenbone's active detection results, without a separately recorded command execution transcript.

Potential Business Impact

If similar weaknesses existed on a production server, an attacker could potentially:

- Execute unauthorized commands.
- Access or modify sensitive information.
- Disrupt business applications.
- Establish unauthorized persistence.
- Use the compromised system as a starting point for further attacks.

The severity of these consequences would depend on the affected system's business importance, privileges, network access, and available security controls.

Risk Analysis

These findings represent significant security concerns because they involve mechanisms that could permit unauthorized execution of commands.

Under the simulated production scenario, all four risks received Critical inherent risk ratings.

Recommended Management Action

Management should prioritize the removal of backdoors, elimination of unnecessary remote execution services, secure software installation practices, and restrictions on access to administrative services.

Remediation should be followed by validation testing to confirm that unauthorized command execution is no longer possible.

4.5 Key Finding 2 — Weak Authentication and Privileged Access

Associated Risks: RISK-003, RISK-008, RISK-011, RISK-012

Risk Category: Identity and Access Management

Observation

The assessment identified multiple authentication weaknesses affecting remote access and database services.

Risk ID	Service	Port	Identified Weakness
RISK-003	rlogin	513/TCP	Greenbone reported root access without a password.
RISK-008	MySQL	3306/ TCP	Successful authentication as database root with an empty password.
RISK-011	VNC	5900/ TCP	Successful authentication using the password `password`.
RISK-012	PostgreSQL	5432/ TCP	Successful authentication using `postgres` / `postgres`.

These findings indicate that authentication mechanisms were absent, weak, or configured with default credentials.

Importantly, database root access is not equivalent to Linux root access. The MySQL finding demonstrated privileged database authentication, not operating system root access.

Similarly, successful VNC authentication did not establish that additional desktop actions were performed.

Potential Business Impact

Weak authentication could allow unauthorized users to:

- Access business applications and databases.
- View or modify sensitive records.
- Perform unauthorized administrative actions.
- Disrupt database availability.
- Compromise the confidentiality and integrity of information.

Risk Analysis

Under the simulated production scenario:

- RISK-003 received a Critical rating.
- RISK-008 received a Critical rating.
- RISK-011 received a High rating.
- RISK-012 received a Critical rating.

These results demonstrate how authentication weaknesses can create significant business exposure even when no sophisticated exploit is required.

Recommended Management Action

Management should require strong, unique credentials for privileged accounts, eliminate default passwords, disable insecure authentication methods, and restrict remote administrative access.

Periodic access reviews and configuration assessments should support continued compliance with authentication requirements.

4.6 Key Finding 3 — Unsupported and Vulnerable Software

Associated Risks: RISK-004, RISK-006

Risk Category: Vulnerability and Configuration Management

Observation

The assessment identified an unsupported operating system and an outdated web application.

RISK-004 — TWiki Vulnerabilities

Greenbone detected a TWiki version identified as `01.Feb.2003`, associated with reported cross-site scripting and command execution vulnerabilities.

The finding was based on version detection. Successful exploitation was not independently demonstrated.

RISK-006 — Unsupported Ubuntu Operating System

Greenbone identified Ubuntu Linux 8.04, which reached end of life on May 9, 2013.

An unsupported operating system generally no longer receives standard vendor security maintenance, increasing the difficulty of managing newly identified vulnerabilities.

Potential Business Impact

Unsupported and vulnerable software can expose organizations to:

- Exploitation of known vulnerabilities.
- Unauthorized access to applications.
- Increased maintenance and recovery costs.
- Operational disruption.
- Difficulty meeting internal security standards and external requirements.

Risk Analysis

Both findings received Critical inherent risk ratings under the simulated production scenario.

The risks highlight the importance of maintaining supported software and managing technology throughout its lifecycle.

Recommended Management Action

Management should establish and enforce software lifecycle requirements, maintain accurate asset inventories, and replace or retire unsupported technology.

Where immediate replacement is not feasible, temporary access restrictions and documented risk treatment decisions should be considered.

4.7 Key Finding 4 — Insecure Remote Administration Services

Associated Risk: RISK-005

Risk Category: Secure Configuration and Network Security

Observation

Greenbone identified an exposed rexec service on TCP port 512.

The rexec protocol is an insecure legacy remote execution mechanism that can transmit credentials without modern encryption protections.

The assessment established that the service was exposed but did not demonstrate credential interception or successful unauthorized command execution through rexec.

Potential Business Impact

If used in a production environment, insecure remote administration services could increase the risk of credential disclosure and unauthorized access.

These weaknesses may also undermine an organization's ability to enforce secure administrative access requirements.

Risk Analysis

RISK-005 received an inherent risk score of 12, resulting in a High rating under the simulated production scenario.

Although Greenbone assigned a technical CVSS score of 10.0, the business risk assessment considered the available evidence and assumed operational consequences separately.

Recommended Management Action

Management should disable insecure legacy remote administration services and replace them with supported, encrypted alternatives such as SSH.

Administrative access should be restricted to authorized users and approved management networks.

4.8 Key Finding 5 — Insecure Application Connector Configuration

Associated Risk: RISK-009

Risk Category: Application Security

Observation

Greenbone identified an Apache Tomcat AJP vulnerability associated with Ghostcat.

The scanner successfully retrieved the application configuration file:

`/WEB-INF/web.xml`

This result demonstrated unauthorized file disclosure through the AJP connector.

Although the vulnerability is associated with potential remote code execution under certain conditions, the available assessment evidence did not demonstrate successful remote code execution.

Potential Business Impact

Unauthorized access to application files could disclose configuration information and potentially support further attacks.

Depending on the contents of exposed files and the application's configuration, the resulting impact could include information disclosure, unauthorized application access, or service compromise.

Risk Analysis

RISK-009 received an inherent risk score of 16, resulting in a High rating under the simulated production scenario.

Recommended Management Action

Management should update vulnerable Tomcat components, disable unnecessary AJP functionality, and restrict access to application connectors.

Validation should confirm that unauthorized retrieval of protected application files is no longer possible.

4.9 Cross-Cutting Risk Themes

Although the assessment documented 12 distinct risks, several recurring security themes emerged.

Risk Theme	Related Risks	Management Consideration
Unauthorized Execution	RISK-001, RISK-002, RISK-007, RISK-010	Remove backdoors and restrict remote execution
Authentication Weaknesses	RISK-003, RISK-008, RISK-011, RISK-012	Strengthen authentication and privileged access
Unsupported or Vulnerable Software	RISK-004, RISK-006	Improve patching and technology lifecycle management
Insecure Remote Services	RISK-005	Eliminate legacy administration protocols
Application Configuration Weaknesses	RISK-009	Secure application connectors and restrict exposure

These themes are useful because management can address related risks through coordinated security initiatives rather than treating every vulnerability as an isolated problem.

For example, a secure configuration management program could help reduce exposure from unnecessary remote services, weak authentication settings, and insecure application configurations.

Similarly, an effective vulnerability management program could support the identification, prioritization, remediation, and ongoing monitoring of unsupported or vulnerable software.

4.10 Risk Prioritization Considerations

The Risk Treatment Plan assigned nine risks to Priority 1 and three risks to Priority 2.

Priority	Number of Risks	Recommended Approach
P1	9	Prioritize management review and corrective action
P2	3	Plan remediation according to exposure, business impact, and available resources

Priority assignments were derived from the provisional inherent risk ratings.

In an actual organization, final prioritization should also consider:

- Business criticality of affected assets
- Availability of compensating controls
- Exposure to relevant threat actors
- Operational dependencies
- Remediation complexity
- Organizational risk appetite

The assessment did not establish formal remediation deadlines or obtain management approval for treatment decisions.

4.11 Overall Risk Analysis

The assessment demonstrated that the Metasploitable system contains multiple significant security weaknesses.

Several findings provided direct evidence of unauthorized command execution, successful authentication using weak credentials, or unauthorized access to application files.

Other findings identified vulnerable software versions, insecure services, and potential backdoor functionality without independently demonstrated exploitation.

Under the simulated production scenario, the combined findings would warrant prioritized corrective action because of their potential consequences for system security and business operations.

However, the assessment was conducted against an intentionally vulnerable training system, and the business risk ratings were illustrative.

No conclusion is made regarding the security posture of an actual production organization.

4.12 Section Conclusion

The detailed review of the 13 Critical Greenbone results produced 12 distinct risks, each supported by documented technical evidence and a provisional business risk assessment.

The analysis identified five principal areas of concern:

1. Unauthorized remote command execution
2. Weak authentication and privileged access
3. Unsupported and vulnerable software
4. Insecure remote administration services
5. Insecure application connector configurations

The findings provide a foundation for evaluating relevant internal control considerations and developing risk-based remediation recommendations.

The next section examines how the identified risks relate to the COSO Internal Control Framework and NIST SP 800-53 security controls.